스냅 N 빵 보안 설계 문서

작성일: 2026-11-02 · 대상: 스냅 N 빵 1 차 출시 (무로그인, React + Spring Boot + MySQL, PWA)

1. 개요와 위협 모델

스냅 N 빵은 회원가입이 없는 서비스라 "링크를 아는 사람 = 접근 권한자"가 되기 쉽습니다. 따라서 로그인 대신 **추측 불가능한 ID + 역할별 토큰 + 서버 측 권한 검증 + 데이터 자동 삭제**로 보안을 구성합니다.

보호할 자산

- 총무 계좌번호·예금주 (가장 민감)
- 참여자 이름, 정산 금액, 입금 상태
- 영수증 이미지 (상호명, 카드 정보가 찍혔을 수 있음)
- 총무 토큰·참여자 토큰, Gemini API 키, DB 접속 정보

주요 위협

- 링크 추측·유출로 타인의 정산 열람
- 타인의 이름 선점, 송금 상태 위조·변조
- 총무 토큰 탈취 (정산 관리 권한 장악)
- API 키 노출로 인한 비용 폭탄
- 영수증 이미지·텍스트를 통한 프롬프트 인젝션
- SQL 인젝션, XSS, 악성 링크
- 계좌번호의 장기 보관과 유출

2. 우선순위 요약

우선순위	항목	한 줄 요약
필수 (P0)	키·DB 정보 서버 관리	환경변수로만 관리, 저장소 커밋 금지
필수 (P0)	서버 측 권한 검증	모든 요청에서 ID 와 토큰을 서비스 계층에서 확인
필수 (P0)	SQL 인젝션 방지	MyBatis #{} 바인딩만 사용

우선순위	항목	한 줄 요약
필수 (P0)	랜덤 ID·토큰	정산 ID 21 자 이상, 토큰은 해시로 저장
필수 (P0)	이름 점유·송금 상태 통제	선점 방지, 본인 상태만 변경
중요 (P1)	계좌 정보 삭제 정책	공유 90 일 뒤 삭제, 총무 삭제 시 즉시 삭제
중요 (P1)	입력 검증·XSS·링크 검증	이름, 송금 링크 등
중요 (P1)	호출 횟수 제한	AI 호출·정산 생성·점유·폴링
권장 (P2)	CORS·보안 헤더, 의존성 점검, PWA 캐시	배포 직전 점검

3. 키와 설정 관리

- Gemini API 키와 DB 비밀번호는 서버의 환경변수로만 주입합니다. application.yml 에는 값을 직접 적지 않고 `${GEMINI_API_KEY}` 형태로 참조합니다.
- 프론트엔드(Vite)에서는 `VITE_` 접두사가 붙은 값이 브라우저 번들에 포함됩니다. 프론트에는 비밀 값을 두지 않고 서버 주소 같은 공개 값만 둡니다.
- `.env`, `application-local.yml` 등은 `.gitignore`에 포함하고, 값이 빈 예시 파일만 저장소에 올립니다.
- 키가 한 번이라도 저장소에 올라갔다면 즉시 폐기하고 재발급합니다.
- Gemini 콘솔에서 사용량 한도와 예산 알림을 설정합니다.

4. AI 호출 보안 (Gemini)

4.1 업로드 검증

- 허용 형식(jpeg, png, webp)과 최대 크기(예: 5MB)를 서버에서 검사하고, Spring 의 multipart 크기 제한도 함께 설정합니다.
- 클라이언트에서 장변 1600px 정도로 리사이즈·압축한 뒤 업로드하면 비용과 지연이 줄어듭니다.
- 영수증 원본 이미지는 서버에 저장하지 않고 파싱 후 즉시 폐기합니다.

4.2 프롬프트 인젝션 대응

- 영수증 속 텍스트는 "지시"가 아니라 "데이터"로만 취급하도록 시스템 프롬프트에 명시합니다.
- 모델 출력은 정해진 JSON 구조로 파싱해 검증하고, 맞지 않으면 버립니다.

- 이름 길이, 가격 범위(0 이상 정수, 상한 설정)를 서버에서 제한합니다.
- 모델 응답을 HTML 로 직접 렌더링하지 않고 항상 텍스트로 출력합니다.

4.3 남용 방지

- IP 단위로 파싱 API 호출 횟수를 제한합니다. (예: IP 당 시간당 20 회)
- 한 정산에서 허용하는 차수와 메뉴 수에 상한을 둡니다.

5. 식별자와 토큰 설계

5.1 식별자

- 정산 ID 는 SecureRandom 기반 랜덤 값(nanoid 21 자 등)을 사용합니다. 순차 번호나 짧은 코드는 쓰지 않습니다.
- 정산 링크는 **정산 ID 만** 담습니다. 토큰이나 계좌번호를 URL 에 넣지 않습니다. (Referrer, 브라우저 기록, 공유 시 유출 방지)
- 정산 목록을 전체 조회하는 API 는 만들지 않습니다.

5.2 토큰 종류

토큰	발급 시점	저장 위치	권한
총무 토큰	정산 생성 시	총무 브라우저, DB 에는 SHA-256 해시	정산 삭제, 입금 확인, 점유 해제, 입금 현황 조회
참여자 토큰	이름 점유 시	참여자 브라우저, DB 에는 해시	본인 금액·계좌 열람, 본인 송금 신고

- 토큰은 SecureRandom 으로 128 비트 이상 생성하고, `Authorization: Bearer` 헤더로 전달합니다. URL 쿼리에는 넣지 않습니다.
- 해시 비교는 MessageDigest.isEqual 같은 상수 시간 비교를 사용합니다.

5.3 열람 범위

- 정산 링크만으로는 **제목과 참여자 이름, 점유 여부**만 보입니다.
- 이름을 점유해 참여자 토큰을 받아야 **본인의 금액·메뉴 내역·계좌번호**가 보입니다. 다른 사람의 금액은 보이지 않습니다.
- 존재하지 않는 정산과 삭제된 정산은 같은 응답(404 한 가지 메시지)으로 처리해 ID 추측에 단서를 주지 않습니다.

6. 이름 점유와 송금 상태 통제

6.1 이름 점유

- 점유는 `token_hash IS NULL` 인 행만 갱신하는 UPDATE 한 번으로 처리합니다. 영향 행이 1 일 때만 성공으로 보고, 동시에 같은 이름을 눌러도 한 명만 성공합니다.
- 점유 요청에는 호출 횟수 제한을 둬서 이름을 연속으로 선점하는 장난을 막습니다.
- 잘못된 점유는 총무가 해제할 수 있고, 해제하면 해당 참여자의 토큰과 송금 상태가 초기화됩니다.

6.2 송금 상태

- 상태는 미입금 → 송금 신고(참여자) → 입금 확인(총무)의 3 단계입니다.
- 참여자의 "송금했어요"는 자기 신고일 뿐이며, 최종 확정은 총무가 은행 앱 입금 내역과 대조해 합니다.
- 참여자는 자기 자신의 미입금과 송금 신고만 변경할 수 있고, 총무만 입금 확인을 할 수 있습니다.
- 총무는 `is_host` 참여자로 항상 입금 확인 상태이며, DB 제약으로 한 정산에 한 명만 허용합니다.
- 권한 검증은 컨트롤러가 아닌 서비스 계층에서 수행하고, 모든 쿼리에 정산 ID 조건을 포함해 다른 정산의 데이터에 접근하지 못하게 합니다.

7. 총무 토큰 보호와 분실

- 총무 토큰은 총무 브라우저 localStorage 에 있으므로 XSS 방어가 곧 정산 보호입니다. 입력 이스케이프와 CSP 를 반드시 적용합니다.
- **1 차 출시에는 복구 기능이 없습니다.** 기기를 바꾸거나 브라우저 데이터를 지우면 해당 정산의 관리 권한을 잃습니다. 참여자의 송금 신고와 열람은 계속 동작하며, 정산은 90 일·12 개월 정책에 따라 자동 삭제됩니다.
- 이 사실을 정산 링크 화면에 안내합니다. ("이 기기에서만 입금 확인을 할 수 있어요")
- 2 차 업데이트에서 복구 코드를 도입합니다.

8. 데이터베이스 보안 (MySQL, MyBatis)

- **SQL 인젝션**: MyBatis 에서는 `#{}` 파라미터 바인딩만 사용하고 `${}`는 쓰지 않습니다. (정렬 컬럼 등 불가피한 경우는 허용 목록으로 검증)
- **계정 권한**: 애플리케이션 전용 DB 계정을 만들고 해당 스키마에 필요한 권한(SELECT, INSERT, UPDATE, DELETE)만 부여합니다. root 는 쓰지 않습니다.
- **네트워크**: DB 포트는 외부에 공개하지 않고 서버에서만 접근하게 합니다.
- **반환 범위**: 계좌번호는 참여자 토큰 또는 총무 토큰이 검증된 요청에서만 반환하고, 입금 현황 폴링 응답에는 포함하지 않습니다.

- **백업**: 백업 파일에도 계좌번호가 포함되므로 접근을 제한하고 보관 기간을 정합니다.

9. 개인정보와 데이터 삭제 정책

대상	정책
총무가 정산 삭제	참여자·차수·메뉴·계좌 정보를 즉시 완전 삭제 (CASCADE)
정산 계좌 정보	링크 공유 90 일 뒤 계좌·송금 링크만 자동 삭제 (정산 기록은 유지)
정산 전체	생성 12 개월 뒤 자동 삭제. 연락처가 없어 사전 알림이 어려우므로 앱 안에서 고지
영수증 이미지	저장하지 않음
로그	계좌번호·토큰·이미지를 기록하지 않음

- **최소 수집**: 계좌번호·은행·예금주 외에는 받지 않습니다. 참여자는 실명이 아닌 별칭을 쓰도록 안내합니다.
- **정리 작업**: Spring @Scheduled 로 하루 1 회 실행하고, 실행 결과(삭제 건수)만 로그로 남깁니다.
- **localStorage**: 총무 프로필(계좌), 토큰, 최근 명단을 기기에 저장하므로, 저장된 정보를 직접 삭제하는 버튼을 프로필 화면에 제공합니다.
- **고지**: 서비스 내에 개인정보 안내(수집 항목, 보관 기간, 삭제 방법, 총무 기기 변경 시 권한 상실)를 노출합니다. 실사용자를 받기 전에 반드시 필요합니다.

10. 입금 현황 갱신(폴링)의 보안

- 폴링 요청도 총무 토큰과 정산 ID 를 매번 검증합니다.
- 폴링 주기는 서버 부하를 고려해 수 초 이상으로 두고, 정산 단위로 호출 횟수를 제한합니다.
- 응답에는 이름과 입금 상태만 담고 계좌번호·토큰은 담지 않습니다.

11. 웹 애플리케이션과 PWA 보안

11.1 입력 검증과 XSS

- 참여자 이름, 가게 이름, 메뉴명, 정산 제목은 길이를 제한하고 화면에서는 항상 이스케이프된 텍스트로 렌더링합니다. (React 의 dangerouslySetInnerHTML 사용 금지)
- 서버에서도 동일하게 검증합니다. (Bean Validation 등) 클라이언트 검증만 믿지 않습니다.

11.2 외부 링크

- 송금 링크는 허용 도메인 목록(예: qr.kakaopay.com)으로만 받습니다. 토스 링크는 사용자가 입력한 주소가 아니라 서버가 은행·계좌로 직접 만듭니다.
- javascript:, data: 등 스킴은 차단하고, 외부 링크에는 rel="noopener noreferrer"를 적용합니다.

11.3 CORS 와 헤더

- CORS 는 프론트엔드 도메인만 허용하고 와일드카드(*)는 쓰지 않습니다.
- HTTPS 전용으로 운영하고, 보안 헤더(X-Content-Type-Options, Referrer-Policy: strict-origin-when-cross-origin 등)와 CSP 를 설정합니다. 정산 링크가 외부로 새지 않도록 Referrer 정책이 특히 중요합니다.

11.4 PWA

- 서비스 워커는 정적 자원(HTML, JS, CSS, 아이콘)만 캐시하고, `/api` 응답은 캐시하지 않습니다. 계좌번호가 기기 캐시에 남지 않게 하기 위해서입니다.
- manifest 에는 비밀 값을 넣지 않습니다.

11.5 오류 응답과 남용

- 오류 응답에 스택 트레이스, SQL 문, 내부 경로를 노출하지 않습니다.
- 정산 생성, 이름 점유, 파싱 API 에 호출 횟수 제한을 적용합니다. (Spring 필터, Bucket4j 또는 호스팅 서비스의 기능)
- Maven 과 npm 의 의존성 취약점을 주기적으로 점검합니다. (Dependabot, npm audit)

12. 일정별 적용 계획

기간	보안 작업
1 주 (11/2~11/8)	키·DB 정보 환경변수 분리, .gitignore 점검, DB 전용 계정, 업로드·출력 검증, MyBatis 바인딩 규칙
2 주 (11/9~11/15)	정산 ID·토큰 발급과 해시 저장, 서비스 계층 권한 검증, 이름 점유(원자적 UPDATE), 열람 범위 제한, 링크 도메인 검증
3 주 (11/16~11/20)	삭제·정리 스케줄러, 호출 횟수 제한, CORS·보안 헤더, 서비스 워커 캐시 범위, 오류 응답 정리
마무리 (11/21~11/25)	권한 우회 테스트(다른 정산·다른 참여자 접근, 토큰 없이 접근 시도), 로그 점검, 개인정보 안내 문구

13. 출시 전 체크리스트

- ☐ 저장소와 브라우저 번들에 Gemini 키·DB 비밀번호가 없는가
- ☐ 프론트 VITE_ 환경변수에 비밀 값이 없는가
- ☐ 정산 ID 가 21 자 이상 랜덤 값인가
- ☐ 링크 URL 에 토큰·계좌번호가 포함되지 않는가
- ☐ 토큰이 해시로만 저장되고 서비스 계층에서 검증되는가
- ☐ 토큰 없이 금액·계좌번호를 조회할 수 없는가
- ☐ 동시에 같은 이름을 점유해도 한 명만 성공하는가
- ☐ 참여자가 타인의 송금 상태를 바꿀 수 없는가
- ☐ 모든 MyBatis 쿼리가 #{} 바인딩을 쓰고 정산 ID 조건을 포함하는가
- ☐ DB 가 전용 계정을 쓰며 외부에서 접근할 수 없는가
- ☐ 파싱 결과가 서버에서 검증되고 영수증 원본이 저장되지 않는가
- ☐ 사용자 입력 URL 이 허용 도메인으로 제한되는가
- ☐ 이름·메뉴명·제목이 이스케이프되어 렌더링되는가
- ☐ CORS 가 프론트 도메인만 허용하는가
- ☐ 오류 응답에 내부 정보가 노출되지 않는가
- ☐ 로그에 계좌번호·토큰이 남지 않는가
- ☐ 정산 삭제, 계좌 정보 90 일 삭제, 12 개월 삭제가 동작하는가
- ☐ 서비스 워커가 API 응답을 캐시하지 않는가
- ☐ 개인정보 안내와 총무 기기 변경 안내가 화면에 있는가